

**— AXE C · LES PERMISSIONS DE L'ANNUAIRE**

Le trousseau de clés que **personne** n'a inventorié

Vos groupes d'administration ne sont pas protégés par le groupe — mais par une liste, gravée sur chaque objet, que vous n'avez jamais lue.

Vous le savez : pour entrer dans le groupe « Admins du domaine », il faut déjà être administrateur. C'est la règle, elle est solide. Et pourtant, il existe une autre porte — une serrure posée sur l'objet lui-même, qu'un compte sans le moindre privilège peut parfois actionner. Cette fiche vous apprend à lire cette serrure, et à débusquer celles qui ont été mal posées.

■ L'IDÉE REÇUE

« Mes groupes d'administration sont verrouillés — seuls les admins peuvent y toucher. »

En réalité — qui peut modifier un objet d'Active Directory ne dépend pas du groupe auquel on appartient, mais de la **liste de contrôle d'accès** gravée sur l'objet lui-même. Un seul droit mal placé sur cette liste, et le verrou s'ouvre — sans qu'aucune appartenance de groupe ne soit jamais requise.

1 ACE

Une ligne suffit

Une seule entrée de contrôle d'accès — une ACE — accordée par erreur sur un groupe sensible suffit à transformer un compte ordinaire en administrateur du domaine. Et cette ligne n'apparaît dans aucun rapport d'appartenance de groupe.

AU SOMMAIRE DE CETTE FICHE**1****Le déclic**

L'idée reçue, l'analogie du trousseau, l'impact métier.

2**Le mécanisme**

La DACL, les ACE, les droits qui font basculer un objet.

3**La salle des machines**

Vérifier, comprendre l'attaque, corriger et détecter.

1

NIVEAU 1 — POUR COMPRENDRE

Le déclic

Nous raisonnons tous de la même façon. Pour savoir qui peut faire quoi dans l'annuaire, nous regardons les groupes : qui est « Admin du domaine », qui est « Opérateur de compte ». Le groupe, pour nous, c'est le trousseau de clés. On l'ouvre, on lit les noms, et on croit savoir qui détient le pouvoir.

C'est une vue incomplète. À côté de ce trousseau central, chaque objet de l'annuaire — chaque compte, chaque groupe, chaque unité d'organisation — possède sa propre petite serrure, et la liste des clés qui l'ouvrent est gravée sur l'objet lui-même.

Reprenons l'image. Un immeuble a bien un jeu de passes central, soigneusement géré. Mais chaque porte possède aussi son barillet, et le syndic a pu, au fil des années, distribuer des clés individuelles : une au plombier pour la chaufferie,

une à l'ancien gardien, une à un voisin « le temps des travaux ». Ces clés ne figurent sur aucun trousseau. Elles n'en ouvrent pas moins les portes.

Dans Active Directory, cette liste de clés gravée sur chaque objet porte un nom : la **liste de contrôle d'accès**, ou ACL. C'est elle, et non l'appartenance à un groupe, qui décide en dernier ressort qui a le droit de modifier l'objet.

Et voici le point qui dérange : quand vous auditez le groupe « Admins du domaine » en listant ses membres, vous lisez le trousseau central. Vous ne voyez pas les clés individuelles. S'il existe quelque part une clé qui dit « ce compte-ci peut s'ajouter lui-même au groupe », elle n'apparaîtra dans aucune liste de membres — jusqu'au jour où quelqu'un s'en sert.

« Le groupe vous dit qui détient le pouvoir aujourd'hui. L'ACL vous dit qui peut le prendre demain. »

POURQUOI ÇA COMPTE — L'IMPACT MÉTIER

Un audit d'appartenance de groupe — l'exercice que tout le monde fait — ne révèle qu'une moitié de la réalité. L'autre moitié, ce sont les permissions posées objet par objet : elles s'accumulent au fil des migrations, des dépannages dans l'urgence, des produits tiers installés avec des droits trop larges « pour que ça marche ». Personne ne les inventorie, parce qu'elles sont invisibles tant qu'on ne les regarde pas explicitement. Un attaquant, lui, les regarde dès la première heure : c'est par là qu'il cherche son chemin vers vos comptes les plus précieux.

2

NIVEAU 2 — LE FONCTIONNEMENT RÉEL

Le mécanisme

Chaque objet d'Active Directory porte un **descripteur de sécurité**. À l'intérieur, la pièce qui nous intéresse est la **DACL** — la liste de contrôle d'accès discrétionnaire. Cette DACL est une suite d'entrées appelées **ACE** : chaque ACE désigne un bénéficiaire (un compte, un groupe) et lui accorde — ou lui refuse — un droit précis sur l'objet.

Tous les droits ne se valent pas. La plupart sont anodins : lire un attribut, consulter le nom. Mais une poignée d'entre eux sont des **droits de prise de contrôle** : qui les détient sur un objet peut, en pratique, en faire ce qu'il veut. En voici les trois principaux.

DROIT CRITIQUE

GenericAll

Le contrôle total. Le détenteur peut tout faire sur l'objet : changer un mot de passe, modifier n'importe quel attribut, ajouter un membre. La clé maîtresse.

DROIT CRITIQUE

WriteDACL

Le droit de réécrire la liste elle-même. Qui le possède peut s'accorder *tous* les autres droits. Une clé qui fabrique des clés.

DROIT CRITIQUE

WriteOwner

Le droit de devenir propriétaire de l'objet. Or le propriétaire peut toujours réécrire la DACL. Même résultat, autre chemin.

À ces trois-là s'ajoutent des droits plus ciblés, tout aussi décisifs selon l'objet : **WriteProperty** sur l'attribut d'appartenance d'un groupe permet d'y ajouter qui l'on veut ; le droit étendu **Reset Password** permet de redéfinir le mot de passe d'un compte sans connaître l'ancien ; le droit étendu **DS-Replication-Get-Changes**, posé sur le domaine, ouvre la porte au DCSync. Le principe est partout le même : la question n'est jamais « à quel groupe appartiens-tu ? », mais « ton nom figure-t-il dans une ACE de prise de contrôle ? ».

Objet : groupe « Admins du domaine »

Descripteur de sécurité → DACL → suite d'ACE

Bénéficiaire qui	Domain Admins	GenericAll	ACE attendue — légitime
	Administrators	GenericAll	ACE attendue — légitime
	j.martin utilisateur ordinaire	WriteDACL prise de contrôle	ACE de trop — le passe-partout !

La DACL se lit ligne à ligne : deux ACE légitimes, et une troisième que personne n'a remarquée.

Schéma 1 — Une DACL et ses ACE : l'entrée de trop se cache au milieu des entrées normales.

SOUS L'ÉCORCE

« Mes comptes les plus sensibles sont sûrement épargnés : leurs ACL sont les mieux gardées. » — C'est l'inverse qui est vrai, et pour une raison subtile. Les objets les plus sensibles — les membres des groupes à hauts privilèges — sont protégés par un mécanisme nommé **AdminSDHolder** : toutes les heures, un processus réécrit leur DACL pour la conformer à un modèle de référence. Excellent garde-fou... sauf si l'attaquant modifie le modèle lui-même. Une ACE malveillante ajoutée sur l'objet AdminSDHolder est alors copiée, automatiquement et toutes les heures, sur l'ensemble de vos comptes privilégiés. Le gardien devient le complice.

3

NIVEAU 3 — SUR LE TERRAIN

La salle des machines

Trois gestes, toujours dans le même ordre : **vérifier** qui détient des droits sur vos objets sensibles, **comprendre** ce qu'un attaquant en ferait, puis **corriger et détecter**.

1 Vérifier

Commençons par le diagnostic. Cette commande lit la DACL d'un objet et n'affiche que les ACE accordant des droits de prise de contrôle — à exécuter depuis un poste disposant du module Active Directory (RSAT).

LA COMMANDE DU JOUR — LIRE LES ACE D'UN OBJET

```
PS C:\> $acl = Get-Acl "AD:CN=Admins du domaine,CN=Users,DC=adcompagnon,DC=lab"
PS C:\> $acl.Access | Where-Object { $_.ActiveDirectoryRights `
>> -match 'GenericAll|WriteDacl|WriteOwner|WriteProperty' } |
>> Select-Object IdentityReference, ActiveDirectoryRights
```

Mot à mot. `Get-Acl` avec le préfixe `AD:` lit le descripteur de sécurité de l'objet ; `.Access` en extrait les ACE ; le filtre ne retient que les droits dangereux. **Tout bénéficiaire affiché qui n'est pas un groupe d'administration connu est une anomalie à investiguer.**

```
Administrateur : Windows PowerShell

PS C:\> $acl.Access | Where ... | Select Identity, Rights

IdentityReference      ActiveDirectoryRights
-----
ADCOMPAGNON\Domain Admins GenericAll
BUILTIN\Administrators GenericAll
ADCOMPAGNON\j.martin WriteDacl
PS C:\>
```

! L'anomalie

Les deux premières lignes sont des groupes d'admin attendus.

j.martin n'a rien à y faire.

Capture simulée — la DACL du groupe sur `adcompagnon.lab` : deux ACE légitimes, une ACE de trop.

2 Comprendre l'attaque

Une ACE mal placée n'est pas une faille en soi : c'est un **maillon**. Mis bout à bout, ces maillons forment un chemin d'élévation. Voici comment un attaquant le déroule.

CE QU'UN ATTAQUANT EN FAIT

1 La cartographie

Il collecte toutes les ACL du domaine avec **BloodHound**, qui les transforme en graphe. L'outil calcule alors le plus court chemin entre le compte qu'il contrôle et « Admins du domaine ».

2 L'abus du droit

Le graphe révèle que `j.martin` détient `WriteDacl` sur le groupe cible. Avec **PowerView** ou **impacket-dacledit**, il s'octroie d'abord `GenericAll`, puis s'ajoute comme membre du groupe.

3 La variante discrète

Plutôt que de s'ajouter au groupe — visible — il peut abuser du droit `Reset Password` sur un compte d'administrateur, ou inscrire un SPN sur ce compte pour un **Kerberoasting** ciblé. Aucune appartenance de groupe ne change.

4 La persistance

Une fois admin, il pose sa propre ACE sur l'objet `AdminSDHolder`. Même si on l'expulse du groupe, sa porte dérobée est réinscrite toutes les heures sur tous les comptes privilégiés.

À chaque maillon, c'est une ACE qui ouvre la suivante. Retirez l'ACE de trop, et le chemin se brise.

3 Corriger et détecter

La correction tient en trois gestes. Le premier répare l'anomalie, le deuxième vérifie le gardien, le troisième installe une surveillance durable.

1 Retirer l'ACE de trop

Supprimez l'entrée illégitime de la DACL de l'objet concerné. Vérifiez aussi le **propriétaire** de l'objet : s'il a été changé, un propriétaire non administrateur peut réécrire la DACL à volonté.

● ● ● RETIRER UNE ACE ILLÉGITIME

```
PS C:\> $o = "AD:CN=Admins du domaine,CN=Users,DC=adcompagnon,DC=lab"
PS C:\> $acl = Get-Acl $o
PS C:\> $acl.Access | Where-Object IdentityReference -eq 'ADCOMPAGNON\j.martin' |
>>     ForEach-Object { $acl.RemoveAccessRule($_) }
PS C:\> Set-Acl $o -AclObject $acl
```

2 Inspecter le gardien — AdminSDHolder

Lisez la DACL de l'objet **AdminSDHolder** du domaine. C'est le modèle recopié sur tous vos comptes privilégiés : une ACE illégitime à cet endroit est une porte dérobée qui se réinstalle seule. Elle doit y être traquée en priorité.

3 Mettre les ACL sous surveillance

Faites de l'inventaire des ACL un contrôle régulier, pas un audit ponctuel. Conservez une référence des DACL de vos objets Tier 0 et comparez-la périodiquement : toute dérive devient ainsi visible.

Détecter — les bons événements

La modification d'une DACL est journalisée, à condition d'avoir activé l'audit des changements d'annuaire. Surveillez deux événements.

ID 5136 « Un objet d'annuaire a été modifié ». C'est l'événement clé : lorsque l'attribut modifié est **nTSecurityDescriptor**, c'est une DACL qui vient de changer. Sur un objet sensible, hors fenêtre planifiée, c'est une alerte forte.

ID 4780 « L'ACL d'un compte membre d'un groupe d'administration a été définie ». Cet événement signale précisément le passage d'AdminSDHolder — anormalement fréquent ou inattendu, il trahit une altération du modèle.

Pour une **chasse proactive**, cette commande liste les objets dont le propriétaire n'est pas un administrateur — un signe classique d'ACL détournée :

● ● ● CHASSE — PROPRIÉTAIRES D'OBJETS INATTENDUS

```
PS C:\> Get-ADObject -Filter 'objectClass -eq "group"' -Properties nTSecurityDescriptor |
>>     Select-Object Name, @{N='Owner';E={$_.nTSecurityDescriptor.Owner}}
```

OBSERVATEUR D'ÉVÉNEMENTS — JOURNAL SÉCURITÉ

Event ID 5136

Objet : CN=Admins du domaine,CN=Users,DC=adcompagnon,DC=lab
 Attribut : nTSecurityDescriptor
 Modifié par : ADCOMPAGNON\j.martin
 Type / Valeur : **Valeur ajoutée – ACE : j.martin accorde GenericAll**

! Modification de DACL sur un groupe Tier 0 par un compte ordinaire — investigation immédiate.

VU SUR LE TERRAIN

Lors de l'audit d'une organisation de taille moyenne, l'équipe de sécurité ne trouve aucun compte suspect dans les groupes d'administration : les appartenances sont impeccables. C'est en collectant les ACL qu'un chemin s'allume. Un ancien produit de gestion de parc, déployé des années plus tôt, avait reçu un droit **GenericAll** sur une unité d'organisation entière — « pour simplifier l'installation », disait la documentation de l'éditeur. Cette OU contenait, depuis une réorganisation oubliée, un compte d'administrateur. Le compte de service du produit, dont le mot de passe traînait dans un fichier de configuration, était donc, sans que personne ne l'ait jamais décidé, un administrateur du domaine en puissance. Le correctif tenait en une ACE à retirer.

LE COIN DU DÉCIDEUR

Un audit d'appartenance de groupe — le contrôle que réclament la plupart des référentiels — ne montre que la **moitié** de qui détient le pouvoir dans votre annuaire. L'autre moitié vit dans les permissions, objet par objet, et reste invisible tant qu'on ne l'inventorie pas explicitement. La bonne question pour votre équipe n'est pas « qui est administrateur ? », mais « **qui pourrait le devenir sans que personne ne l'ait décidé ?** ». Inscrivez dans votre socle un principe simple : les permissions sur les objets Tier 0 sont cartographiées, documentées et revues aussi régulièrement que les appartenances de groupe.

L'ÉNIGME DU COMPAGNON — N°03

Sur `adcompagnon.lab`, l'équipe inspecte la DACL du groupe « Admins du domaine » : aucune ACE suspecte, tout est conforme. Pourtant, le compte ordinaire **j.martin** parvient bel et bien à s'ajouter au groupe. Sa DACL est saine — et l'attaque fonctionne quand même. **Où est passée la clé ?**

LA RÉPONSE DU COMPAGNON

Dans l'**héritage**. Une ACE n'est pas toujours posée sur l'objet qu'elle protège : elle peut être définie plus haut, sur l'unité d'organisation parente, avec l'option « s'applique aux objets enfants ». Elle « coule » alors vers le bas et s'applique au groupe — mais en inspectant *seulement* la DACL du groupe, on la voit comme une entrée « héritée » et le regard glisse dessus. La clé n'a pas disparu : elle a été posée à l'étage du dessus. Pour la voir, il faut remonter la chaîne des OU parentes et lire leurs ACE héritables. L'héritage est une commodité d'administration ; c'est aussi l'endroit où une permission dangereuse devient la plus discrète.

LE GLOSSAIRE

ACL — liste de contrôle d'accès : l'ensemble des permissions gravées sur un objet de l'annuaire.

DACL — la partie de l'ACL qui accorde ou refuse des droits ; c'est une suite d'ACE.

ACE — entrée de contrôle d'accès : une ligne qui lie un bénéficiaire à un droit précis.

Descripteur de sécurité — la structure qui porte le propriétaire et la DACL d'un objet.

GenericAll — le droit de contrôle total sur un objet.

WriteDACL — le droit de réécrire la DACL, donc de s'accorder tous les autres droits.

WriteOwner — le droit de devenir propriétaire de l'objet, et donc de réécrire sa DACL.

Droit étendu — permission spéciale comme Reset Password ou la réplication.

AdminSDHolder — objet modèle dont la DACL est recopiée toutes les heures sur les comptes privilégiés.

Kerberoasting — attaque visant le mot de passe d'un compte porteur d'un SPN.

BloodHound — outil qui cartographie les relations et ACL d'AD sous forme de graphe d'attaque.

Héritage — mécanisme par lequel une ACE définie sur une OU s'applique à ses objets enfants.



DANS LE PROCHAIN NUMÉRO

N°04 — AD CS : l'autorité de certification qui signe des laissez-passer à votre place

Comment un modèle de certificat trop permissif délivre, à qui le demande, un badge au nom de l'administrateur.